

# Fifth-Round Beginner-Fix Legal & Compliance Notice (v3.41)

**Document nature:** Compliance reminder for customer profitability, order lifecycle, email PDF, FAQ, data health check, Chat feedback. **Does not constitute legal advice.** Cumulatively applies to all §6 disclaimers in v3.25.10 → v3.40.

**Chinese version:** [POLISH\\_V341\\_LEGAL\\_NOTICE\\_ZH.md](#)

 **Customer MUST** have CPA / legal counsel / internal control + sales/marketing manager review before production use.

 **v3.41 includes highly sensitive outbound functions**

| Function                    | Risk Level                                                                                              | External / Internal      |
|-----------------------------|---------------------------------------------------------------------------------------------------------|--------------------------|
| Email PDF to customer (P5)  |  Outbound            | External — contract risk |
| Customer profitability (P1) |  Pricing strategy    | Internal — must not leak |
| Order lifecycle (P2)        |  Sales visibility    | Internal                 |
| Data health check (P8)      |  IT internal control | Internal                 |
| Chat thumbs feedback (P7)   |  Employee feedback   | Internal                 |
| FAQ (P6)                    |  Static Q&A          | Internal                 |

**1. Email PDF to Customer (P5)  Most Legally Sensitive**

### 1.1 Behavior

- LLM: "email QUO-001 to ABC" → emits ConfirmCard
- After confirm: generates PDF + sends via SMTP to customer's contact\_email
- Default TTL 15 min (shorter than usual 30, emphasizing care)

### 1.2 Legal Risk (critical)

Outbound Email with PDF may carry legal meaning of "offer", "acceptance", "notice":

- **Quotation:** may be "invitation to treat"; if customer misreads as "offer" and accepts → contract formation dispute
- **Sales Order:** may be "acceptance"; customer can claim price/spec/delivery date is fixed
- **Delivery Note:** title-transfer evidence; misdirected = account chaos
- **Invoice-related:** must comply with Uniform Invoice Regulations; erpilot's PDF is **not** a uniform invoice

### 1.3 Wrong Recipient Risk

- **Customer data leak** (PDPA Art. 27)
- **Trade secret leak** (Trade Secrets Act)
- **Competitor gets pricing intelligence**
- **Customer-to-customer confusion** (A sees B's prices)

### 1.4 Customer Internal Control Duties (mandatory)

Before adopting, must:

- ☐ **Designate** final reviewer for outbound emails (typically sales manager / owner)
- ☐ **Restrict** `sales.order.update` permission to authorized personnel
- ☐ **Establish** "pre-send checklist" SOP (recipient / subject / attachment correct)
- ☐ **Configure** SMTP return receipts
- ☐ **Define** "recall / apology" flow for mis-sent emails
- ☐ **Train** employees: **once sent, cannot recall** (unless other side's IT cooperates)

### 1.5 SMTP Configuration Security

- **✗ Do not** use personal Gmail / Yahoo (easily marked spam)
- **✓ Use** company domain SMTP (e.g. `noreply@yourcompany.com.tw` )
- **✓ Configure** SPF / DKIM / DMARC for deliverability + anti-spoof
- **✓ Enable** send audit log (who / when / to whom / what)

### 1.6 erpilot Responsibility Boundary

To the maximum extent permitted by applicable law:

- erpilot **provides** the sending tool, does **not** verify PDF content correctness
- erpilot does **not** verify recipient authenticity
- erpilot does **not** auto-recall emails
- erpilot is **not liable** for **any** contract dispute, PII leak, business loss from wrong recipient / wrong content

## 1.7 Dry-run when SMTP unset

- If `SMTP_HOST` / `SMTP_FROM` not set → auto dry-run (no real send)
- Dry-run **only** shows preview, does **not** leak data
- But customer should **not** assume dry-run = risk-free — test before real production use

# 2. Customer Profitability (P1) ⚖️ Pricing Strategy Sensitive

## 2.1 Behavior

- LLM: "which 5 customers most profitable", "is ABC profitable"
- System calculates  $(\text{revenue} - \text{cost}) \div \text{revenue} \times 100\%$
- Lists top N with ● ● ● grading

## 2.2 Legal / Commercial Sensitivity

Profitability data is:

- **Internal pricing strategy** (core trade secret)
- Leaked to **employees**: may be used for job-hopping leverage (violates confidentiality)
- Leaked to **Customer A**: A can claim "Customer B's margin is lower → I want a discount too"
- Leaked to **competitor**: equivalent to giving away intelligence

## 2.3 Customer Internal Control Duties

- Restrict `sales.order.read` permission to authorized managers only
- Do not **screenshot** / **print** / **export** profitability analysis
- Employees **sign NDA** explicitly including "profitability is trade secret"
- During **employee training**, stress "do not disclose even in private conversations"

## 2.4 Calculation Limits

- Cost based on `Product.standard_cost` — does **not** include labor, manufacturing OH, marketing
- Does not include returns/discounts
- Does not include bad debt
- Does not include opportunity cost (capacity tied up by low-margin customers)
- Customer's **formal financial analysis** should use more complete methods via CPA

## 2.5 erpilot Disclaimer

erpilot's profitability is a **heuristic analysis**; does **not** replace formal financial analysis. erpilot is **not liable** for any loss from pricing decisions / customer selection based on this analysis.

## 3. Order Lifecycle (P2)

### 3.1 Behavior

- "What happened to QUO-001" → shows Quote → SO → Shipment → AR → Payment timeline

### 3.2 Risk

- Timeline contains **contract execution details**
- Given to **competitors**: leaks transaction structure
- Given to **other customers**: PII / trade secret

### 3.3 Customer Responsibility

- Restrict permission: `sales.order.read`
- Disclosing specific transactions externally **requires** counterparty consent

## 4. Data Health Check (P8)

### 4.1 Behavior

- Check duplicate customers / parts / BOM circular / orphan inventory / customers without email / parts without cost
- Show     severity

### 4.2 Limits

- Health check is **heuristic detection**
- Results do **not** replace formal IT audit / internal control review
- Customer's **specific business rules** are not covered

### 4.3 Customer Responsibility

- Issues found should be handled by IT / **internal control lead**
- Should **not** let non-IT employees directly fix (may cause worse data pollution)

## 5. Chat Thumbs Feedback (P7)

### 5.1 Behavior

- User presses  /  → written to AuditLog (action="chat.feedback")

## 5.2 Employee Monitoring Boundary

- Feedback contains **employee satisfaction with system** → may be used for performance evaluation
- Customer must **inform employees**: feedback is for **system improvement**, **not** for HR appraisal
- If used for HR, **prior notice** + **consent** required

## 5.3 PII Handling

- Feedback **comment** field may contain **free text** (employees may write sensitive info)
- Customer must **periodically review** and **redact** sensitive fields
- Retention should match **employee data retention**

# 6. FAQ (P6)

## 6.1 Behavior

- Static 8 common questions (price / offline / multi-user / backup / API key / upgrade / password / ConfirmCard)

## 6.2 Limits

- FAQ is **heuristic hint**, does **not** replace formal contract / SLA / technical support
- "Price" is **public estimate**; actual price per **official quotation**

# 7. Case Studies: Common Misuse

## 7.1 ❌ Don't

- **Email PDF to wrong customer** (e.g. A's quotation sent to B)
- Screenshot profitability and **send to LINE group**
- Use profitability as **employee KPI basis** (employees will argue with customers)
- **Verbally mention** other customers' timelines to a customer
- Mass-mail customer emails without SPF/DKIM (easily marked spam)

## 7.2 ✅ Do

- **Manually verify** recipient + attachment before sending
- Profitability discussed **only in management meetings**, no paper copies
- Use profitability for **internal pricing strategy**, do not leak
- Order tracking is **internal use only**

- SMTP uses company domain + SPF/DKIM/DMARC

## 8. Disclaimer (Cumulative v3.25.10 → v3.41)

To the maximum extent permitted by applicable law:

1. **Email PDF** erpilot does **not** verify PDF content, recipient authenticity, or contract effect of sending. erpilot is **not liable** for **any** contract dispute, PII leak, business loss, customer confusion, or competitor leak from sending.
2. **Customer Profitability** erpilot's profitability is a **heuristic analysis** (standard\_cost-based), does **not** replace formal financial / CPA analysis. erpilot is **not liable** for **any** loss from pricing decisions / customer selection / business strategy based on this analysis.
3. **Order Lifecycle** erpilot does **not** guarantee timeline completeness; **not liable** for PII / trade secret disputes from timeline leakage.
4. **Data Health Check** erpilot's check is **heuristic detection**, does **not** replace formal IT audit. erpilot is **not liable** for loss from undetected data quality issues.
5. **Chat Feedback** erpilot does **not** supervise customer's use of feedback; **not liable** for labor disputes from using feedback for HR appraisal.
6. **FAQ Answers** are **functional reference**, do **not** replace formal contract / SLA / technical support. Price per **official quotation**.

## 9. Pre-Adoption Checklist (v3.41 reinforced)

### 9.1 External Communication (Email) ⚠️ Most Important

- ☐ **Designated** final reviewer for outbound emails
- ☐ **Restricted** `sales.order.update` permission to 2-3 authorized persons
- ☐ **Configured** company domain SMTP + SPF / DKIM / DMARC
- ☐ **Defined** mis-send recall / apology SOP
- ☐ **Tested** real SMTP send + return receipt

### 9.2 Pricing Strategy (Profitability)

- ☐ **Restricted** profitability analysis permission to authorized managers
- ☐ Employees **signed** NDA including profitability clause
- ☐ **Defined** "profitability discussion management meetings only" policy

### 9.3 Employee Feedback

- ☐ **Informed** employees: Chat thumbs is for system improvement, **not** HR appraisal
- ☐ **Defined** sensitive feedback masking process

### 9.4 Data Health

- ☐ **Designated** IT lead for periodic check
- ☐ **Defined** abnormal handling flow (no non-IT direct edits)

### 9.5 Cumulative with Existing Checklists

- ☐ Completed **all** v3.25.10 → v3.40 checklists

## 10. International / Cross-Border Warning

| Region     | Additional Law   | Impact on v3.41                                                                                      |
|------------|------------------|------------------------------------------------------------------------------------------------------|
| eu EU      | GDPR Art. 6 / 32 | Email send requires <b>legal basis</b> ; customer data <b>minimization</b>                           |
| us US      | CAN-SPAM Act     | Email <b>must include opt-out</b> link + company address                                             |
| us US (CA) | CCPA             | Customer has "right not to be sold" — profitability analysis cannot be used for external negotiation |
| cn China   | PIPL             | Cross-border email requires <b>separate consent</b>                                                  |
| jp Japan   | APPI             | Customer data purpose <b>change</b> requires notification                                            |
| sg SG      | PDPA             | DNC list restricts marketing emails                                                                  |

 **erpilot's SMTP sending does not auto-add unsubscribe link / company address — customer must self-comply with the above.**

**Version:** v3.41 (2026-05-22) **Author:** erpilot Legal Team (internal) **Corresponds to code:**

- `backend/app/agents/domains/polish_v341_tools.py` (5 LLM tools + email helper)
- `backend/app/api/chat_feedback.py` (P7 feedback endpoint)
- `frontend-desktop/src/pages/Chat.tsx` (briefMode / pin / thumbs UI)